wk02 — CA·SC 정답 및 해설

- **출제자:** 수연
- **문제지:** `wk02_CA, SC_수연.md`
- **총점:** 25점 (CA 15점, SC 10점)
- **구성:** 모범답안, 핵심 해설, 부분점수 채점 기준

문제 1. CA — RAID 구성과 장애 허용 [서술형 · 15점]

가. RAID별 데이터 저장 원리 (6점)

- **RAID 5:** 블록 단위 스트라이핑과 분산 단일 패리티를 사용. 디스크 1개 장애 시 남은 데이터 및 패리티로 복원 가능.
- **RAID 6:** 블록 단위 스트라이핑과 독립적인 이중 패리티(P·Q)를 사용. 디스크 2개 동시 장애 시에도 복원 가능.
- **RAID 10 (1+0):** 2개 디스크씩 미러링 그룹 4개를 구성하고, 이 그룹들 사이에 스트라이핑 적용. 패리티 없이 중복 사본으로 보호.

나. 사용 가능 용량 및 보장 장애 허용 개수 (5점)

구성	용량 계산	사용 가능 용량	모든 조합에서 보장되는 동시 장애
RAID 5	(8 − 1) × 2 TB	**14 TB**	**1개**
RAID 6	(8 − 2) × 2 TB	**12 TB**	**2개**
RAID 10	(8 ÷ 2) × 2 TB	**8 TB**	**1개**

주의: RAID 10은 서로 다른 미러링 그룹에서 각각 디스크 하나가 고장 나는 경우 최대 4개까지 견딜 수 있으나, 동일 미러링 그룹의 두 디스크가 함께 고장 나면 데이터 손실. 따라서 **어떤 조합에서도 보장되는 장애 개수는 1개**.

다. 이체 시스템에 적합한 구성과 근거 (4점)

모범 선택: RAID 10

작은 랜덤 쓰기 요청이 빈번한 계좌이체 시스템에서는 RAID 10이 적합. RAID 5·6에 비해 패리티 읽기·계산·갱신 부담이 없으므로 작은 쓰기 성능에 유리. 장애 발생 시 살아 있는 미러에서 교체 디스크로 복제하면 되어 패리티 기반 재구성보다 복구 과정이 상대적으로 단순함. 다만 저장용량 효율은 50%(8 TB)이며, 같은 미러링 그룹의 두 디스크 장애에는 취약.

조건부 대안: 임의의 두 디스크 동시 장애를 반드시 견뎌야 하는 요구사항이 쓰기 성능보다 우선이라면 RAID 6도 타당. 단, 이중 패리티에 따른 쓰기 비용과 복구 부하를 함께 설명할 것.

채점 기준 (15점)

세부 문항	배점	채점 요소
가	6점	RAID 5·6·10의 저장 원리 및 보호 방식 각 2점
나	5점	사용 가능 용량 3개 각 1점(3점), RAID 5·6 보장 장애 개수 각 0.5점(1점), RAID 10의 1개 및 이유 1점
다	4점	랜덤 쓰기 특성 비교 2점, 재구성·가용성 비교 1점, 합리적 선택과 근거 1점

문제 2. SC — XSS와 CSRF의 원리 및 대응 [약술형 · 10점]

가. 공격 원리와 신뢰 관계 차이 (6점)

- **XSS(Cross-Site Scripting):** 공격자가 입력값·게시물·DOM 처리 경로 등에 악성 스크립트를 삽입하여 정상 사용자의 브라우저에서 은행 사이트의 권한으로 실행하도록 유도하는 공격. 계좌정보 노출 또는 사용자 권한 악용 가능.
- **CSRF(Cross-Site Request Forgery):** 로그인된 사용자가 공격자가 만든 페이지·링크 등을 방문했을 때, 브라우저가 세션 쿠키 등 인증정보를 자동으로 포함해 은행 서버에 원치 않는 요청을 보내도록 하는 공격. 서버가 이를 사용자의 정상 의사로 오인하는 것이 핵심.

비교	XSS	CSRF
악용하는 신뢰	브라우저가 은행 출처에서 실행되는 스크립트를 신뢰	서버가 인증된 브라우저 요청을 사용자의 의사로 간주
핵심 문제	신뢰되지 않은 데이터가 실행 가능한 코드로 해석	인증정보가 있다는 사실만으로 사용자 의사를 입증하지 못함

나. 공격별 보호조치 (4점)

XSS 대응

1. **출력 컨텍스트별 인코딩:** HTML 본문·속성·JavaScript·URL 등 출력 맥락에 맞는 인코딩 적용.
2. **HTML 정화 및 안전한 DOM API 사용:** HTML을 허용할 때 허용목록 기반 정화 적용. `innerHTML` 등 위험한 삽입 대신 안전한 텍스트 출력 API 사용.

CSRF 대응

1. **CSRF 토큰 검증:** 이체·정보변경 등 상태 변경 요청에 예측 불가능한 토큰을 포함하고 서버에서 사용자 세션 등과 연계해 검증.
2. **세션 쿠키의 SameSite 설정:** 서비스 특성에 따라 `Lax` 또는 `Strict` 정책으로 교차 사이트 요청에 쿠키가 자동 전송되는 경우를 제한.

보충 해설

- XSS에는 CSP(Content Security Policy)를 추가 방어선으로 활용 가능. CSRF에는 `Origin`/`Referer` 검증을 추가적으로 적용 가능. CSP나 SameSite만으로 모든 공격을 완전히 차단할 수는 없음.
- CSRF는 응답 본문을 읽지 못해도 유효한 요청이 전송되면 성립 가능. XSS 취약점이 존재하면 일부 CSRF 방어책을 우회할 수 있으므로 둘 모두 방어 필요.

채점 기준 (10점)

세부 문항	배점	채점 요소
가	6점	XSS 원리 2점, CSRF 원리 2점, 브라우저·서버 신뢰 관계 차이 2점
나	4점	XSS 대응 2가지 각 1점, CSRF 대응 2가지 각 1점

본 정답은 스터디용 모범답안이며 실제 출제기관의 공식 채점 기준이 아님.